Sysmon TryHackMe Room Write-up

Learn how to utilize Sysmon to monitor and log your endpoints and environments.

Task 4 – Cutting out the Noise

Malicious Activity Overview

Since most of the normal activity or "noise" seen on a network is excluded or filtered out with Sysmon we're able to focus on meaningful events. This allows us to quickly identify and investigate suspicious activity. When actively monitoring a network you will want to use multiple detections and techniques simultaneously in an effort to identify threats. For this room, we will only be looking at what suspicious logs will look like with both Sysmon configs and how to optimize your hunt using only Sysmon. We will be looking at how to detect ransomware, persistence, Mimikatz, Metasploit, and Command and Control (C2) beacons. Obviously, this is only showcasing a small handful of events that could be triggered in an environment. The methodology will largely be the same for other threats. It really comes down to using an ample and efficient configuration file as it can do a lot of the heavy lifting for you.

You can either download the event logs used for this task or you can open them from the Practice directory on the provided machine.

Sysmon "Best Practices"

Sysmon offers a fairly open and configurable platform for you to use. Generally speaking, there are a few best practices that you could implement to ensure you're operating efficiently and not missing any potential threats. A few common best practices are outlined and explained below.

- Exclude > Include

When creating rules for your Sysmon configuration file it is typically best to prioritize excluding events rather than including events. This prevents you from accidentally missing crucial events and only seeing the events that matter the most.

- CLI gives you further control

As is common with most applications the CLI gives you the most control and filtering allowing for further granular control. You can use either Get-WinEvent or wevtutil.exe to access and filter logs. As you incorporate Sysmon into your SIEM or other detection solutions these tools will become less used and needed.

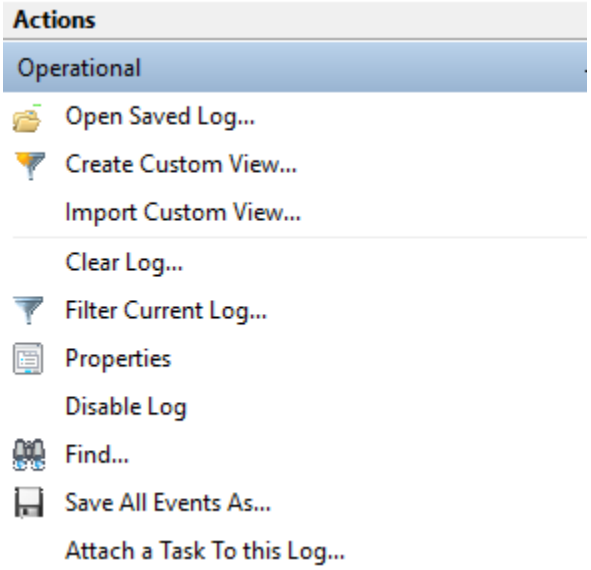
- Know your environment before implementation

Knowing your environment is important when implementing any platform or tool. You should have a firm understanding of the network or environment you are working within to fully understand what is normal and what is suspicious in order to effectively craft your rules.

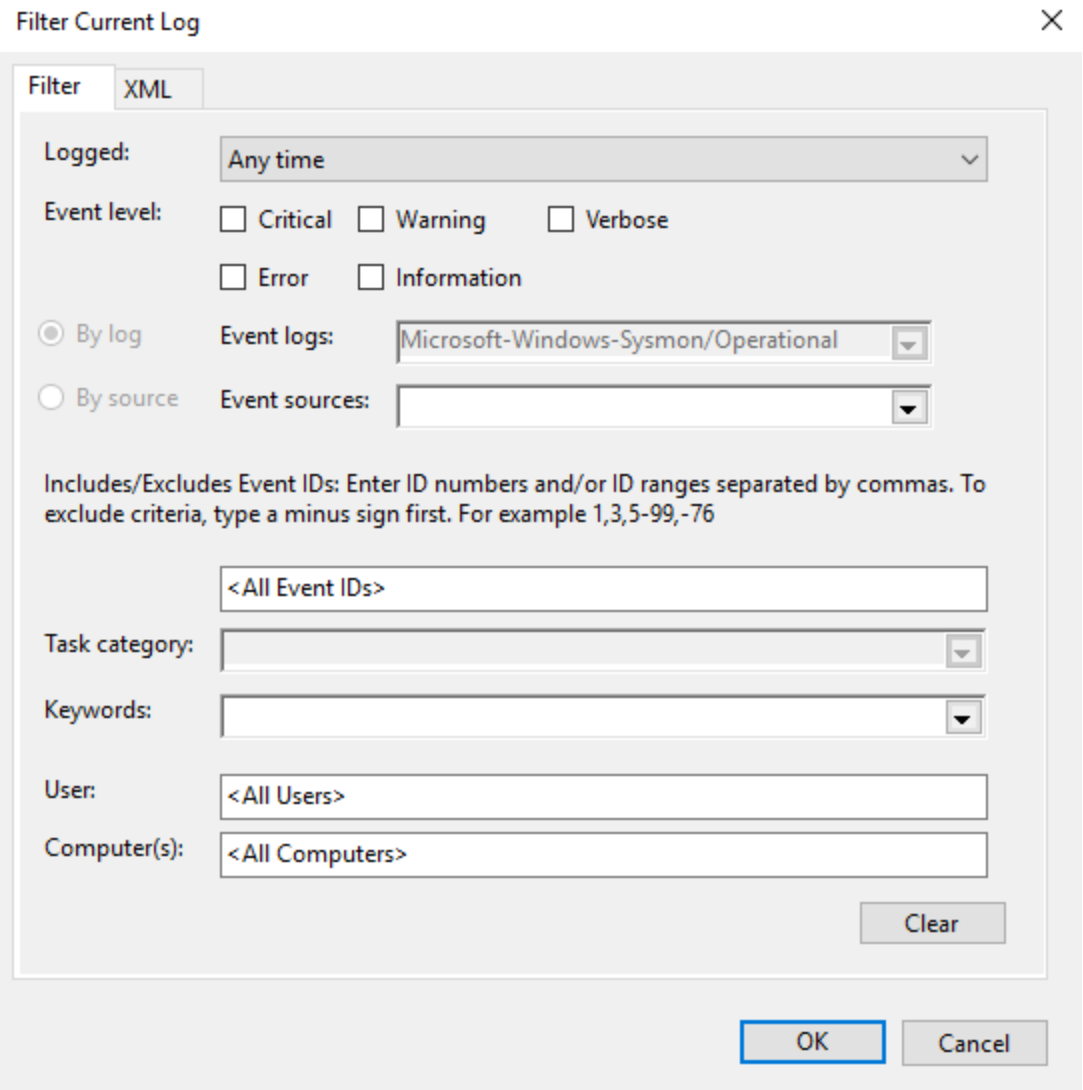
Filtering Events with Event Viewer

Event Viewer might not the best for filtering events and out-of-the-box offers limited control over logs. The main filter you will be using with Event Viewer is by filtering the EventID and keywords. You can also choose to filter by writing XML but this is a tedious process that doesn't scale well.

To open the filter menu select Filter Current Log from the Actions menu.



If you have successfully opened the filter menu it should look like the menu below.



From this menu, we can add any filters or categories that we want.

Filtering Events with PowerShell

To view and filter events with PowerShell we will be using Get-WinEvent along with XPath queries. We can use any XPath queries that can be found in the XML view of events. We will be using wevutil.exe to view events once filtered. The command line is typically used over the Event Viewer GUI as it allows for further granular control and filtering whereas the GUI does not. For more information about using Get-WinEventand wevutil.exe check out the Windows Event Log room.

For this room, we will only be going over a few basic filters as the Windows Event Log room already extensively covers this topic.

Filter by Event ID: */System/EventID=<ID>

Filter by XML Attribute/Name: */EventData/Data[@Name="<XML Attribute/Name>"]

Filter by Event Data: */EventData/Data=<Data>

We can put these filters together with various attributes and data to get the most control out of our logs. Look below for an example of using Get-WinEvent to look for network connections coming from port 4444.

Get-WinEvent -Path <Path to Log> -FilterXPath '*/System/EventID=3 and */EventData/Data[@Name="DestinationPort"] and */EventData/Data=4444'

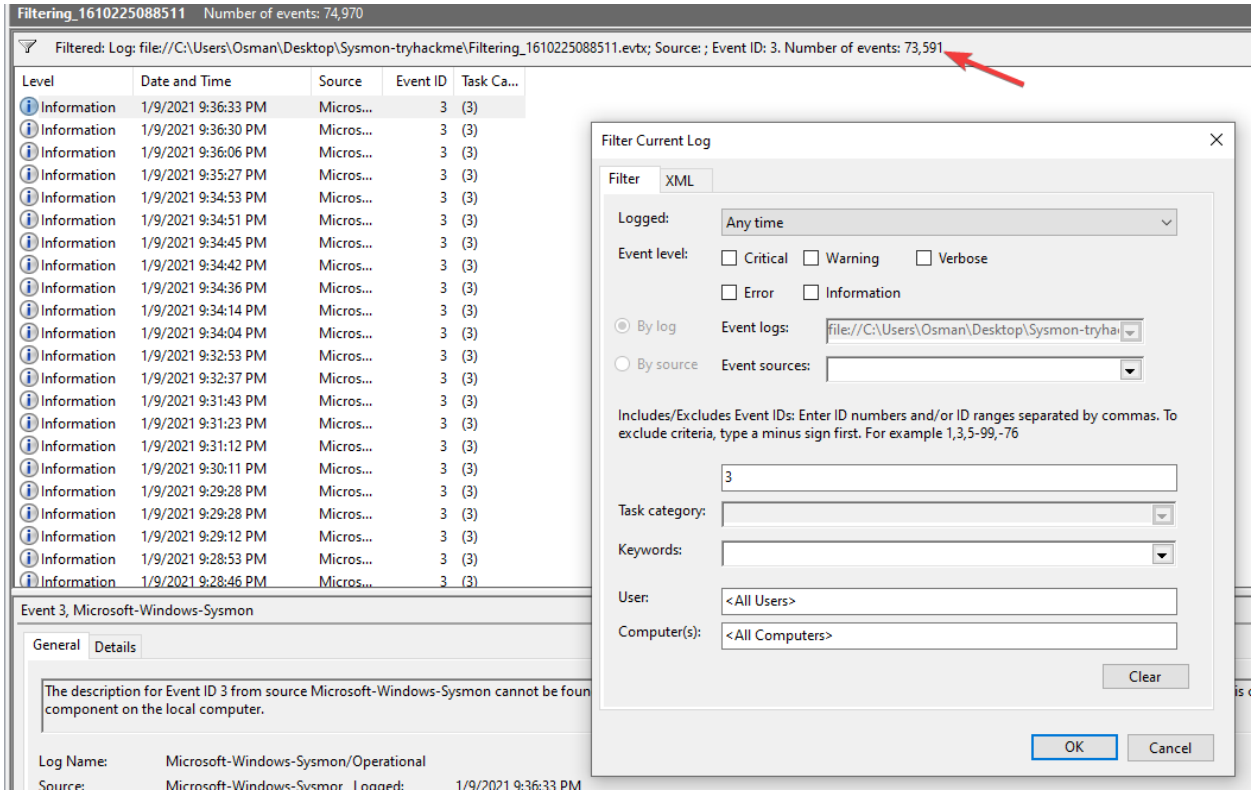
Filtering Events

```
PS C:\Users\THM-Analyst> Get-WinEvent -Path C:\Users\THM-Analyst\Desktop\Scenarios\Practice\Hunting_Metasploit.evtx -FilterXPath '*/System/EventID=3 and */EventData/Data[@Name="DestinationPort"] and */EventData/Data=4444'



   ProviderName: Microsoft-Windows-Sysmon


TimeCreated                     Id LevelDisplayName Message
-----------                     -- ---------------- -------
1/5/2021 2:21:32 AM              3 Information      Network connection detected:...
```

Answer the questions below

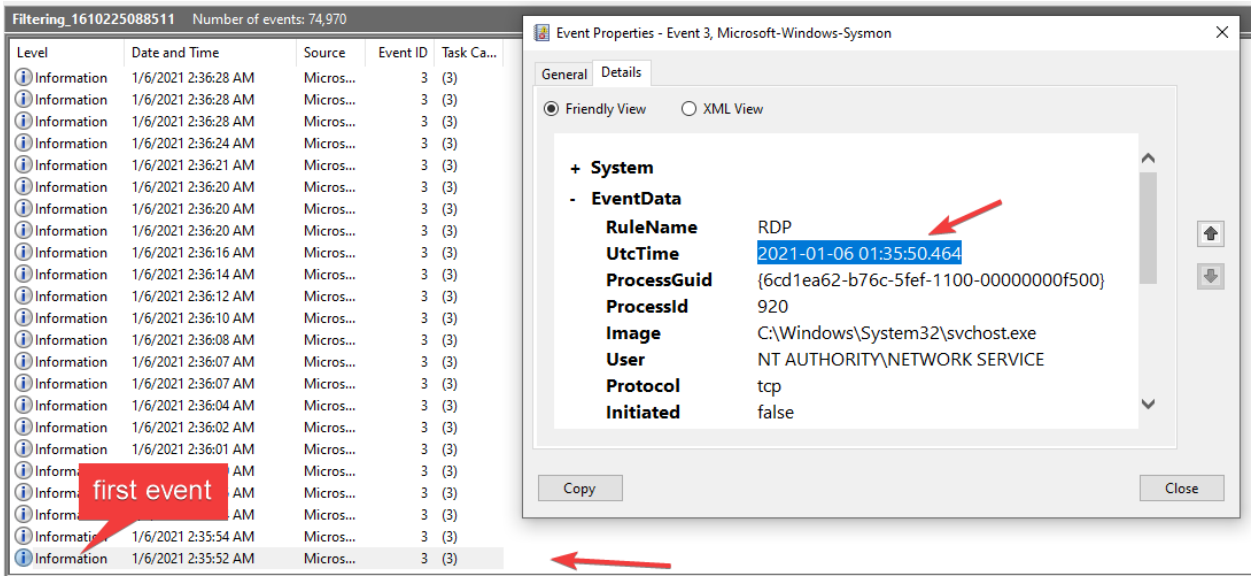
Read the above and practice filtering events.

How many event ID 3 events are in C:\Users\THM-Analyst\Desktop\Scenarios\Practice\Filtering.evtx?



Answer: 73,591

What is the UTC time of the first network event in the same logfile? Note that UTC time is shown only in the "Details" tab.



Answer: 2021-01-06 01:35:50.464

Task 10 – Practical Investigation

Event files used within this task have been sourced from the EVTX-ATTACK-SAMPLES (opens in new tab) and SysmonResources (opens in new tab) Github repositories.

You can download the event logs used in this room from this task or you can open them in the Investigations folder on the provided machine.

Investigation 1 - ugh, BILL THAT'S THE WRONG USB!

In this investigation, your team has received reports that a malicious file was dropped onto a host by a malicious USB. They have pulled the logs suspected and have tasked you with running the investigation for it.

Logs are located in C:\Users\THM-Analyst\Desktop\Scenarios\Investigations\Investigation-1.evtx.

Investigation 2 - This isn't an HTML file?

Another suspicious file has appeared in your logs and has managed to execute code masking itself as an HTML file, evading your anti-virus detections. Open the logs and investigate the suspicious file.

Logs are located in C:\Users\THM-Analyst\Desktop\Scenarios\Investigations\Investigation-2.evtx.

Investigation 3.1 - 3.2 - Where's the bouncer when you need him

Your team has informed you that the adversary has managed to set up persistence on your endpoints as they continue to move throughout your network. Find how the adversary managed to gain persistence using logs provided.

Logs are located in C:\Users\THM-Analyst\Desktop\Scenarios\Investigations\Investigation-3.1.evtx

and C:\Users\THM-Analyst\Desktop\Scenarios\Investigations\Investigation-3.2.evtx.

Investigation 4 - Mom look! I built a botnet!

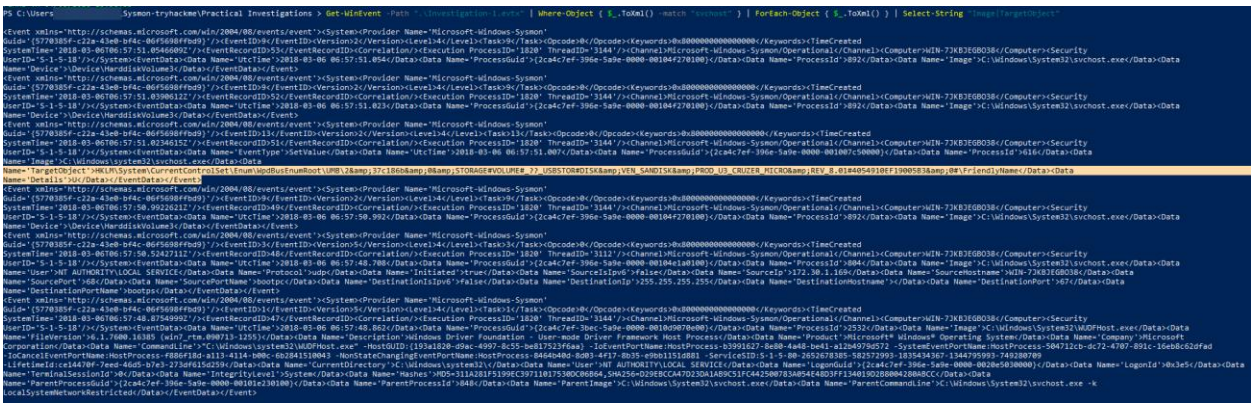
As the adversary has gained a solid foothold onto your network it has been brought to your attention that they may have been able to set up C2 communications on some of the endpoints. Collect the logs and continue your investigation.

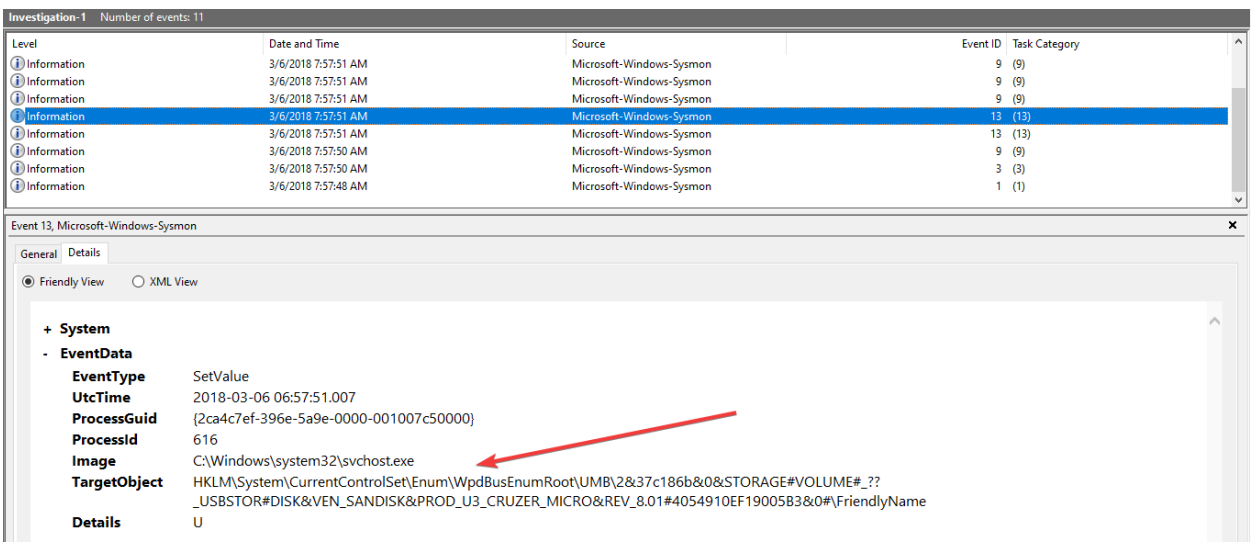
Logs are located in C:\Users\THM-Analyst\Desktop\Scenarios\Investigations\Investigation-4.evtx.

Answer the questions below

What is the full registry key of the USB device calling svchost.exe in Investigation 1?

Get-WinEvent -Path ".\Investigation-1.evtx" | Where-Object { $_.ToXml() -match "svchost" } | ForEach-Object { $_.ToXml() } | Select-String "TargetObject"



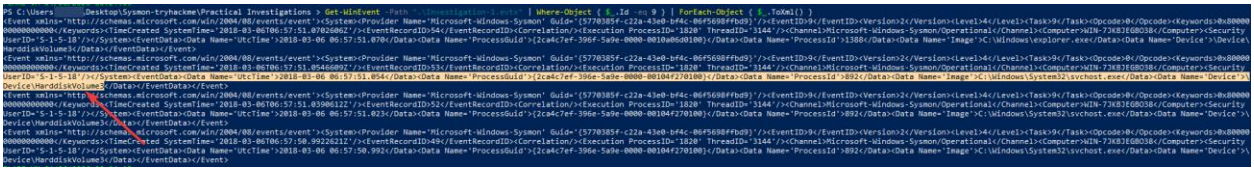


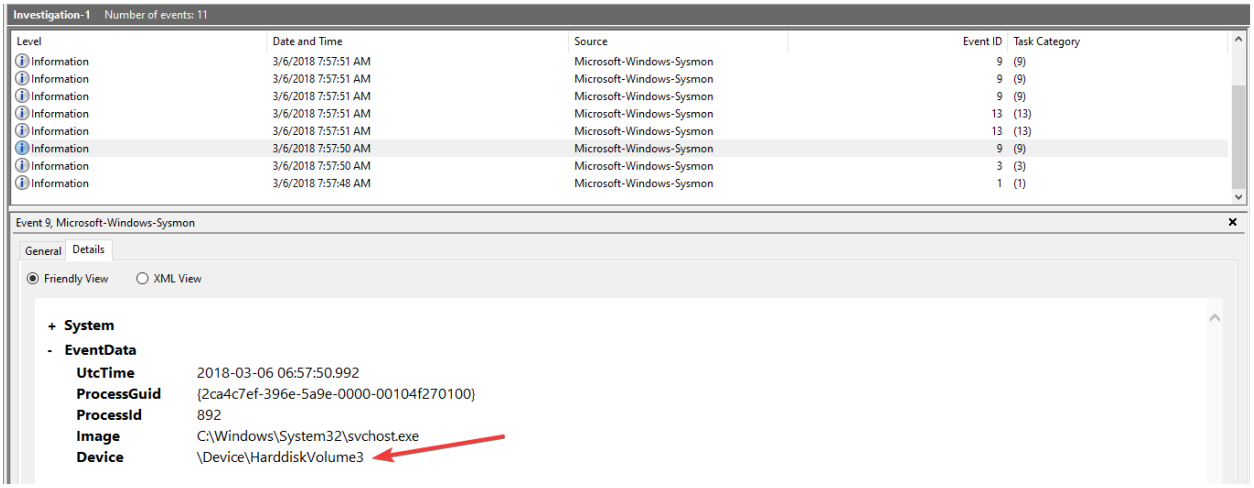
I found the answer using both PowerShell and Event Viewer. PowerShell helped me quickly locate the right Sysmon event in the log, and Event Viewer made it easier to read the fields clearly. In the matching **Event ID 13** event, the **Image** field pointed to svchost.exe and the **TargetObject** field contained the full USB registry key.

Answer: HKLM\System\CurrentControlSet\Enum\WpdBusEnumRoot\UMB\2&37c186b&0&STORAGE#VOLUME#_??_USBSTOR#DISK&VEN_SANDISK&PROD_U3_CRUZER_MICRO&REV_8.01#4054910EF19005B3&0#\FriendlyName

What is the device name when being called by RawAccessRead in Investigation 1?

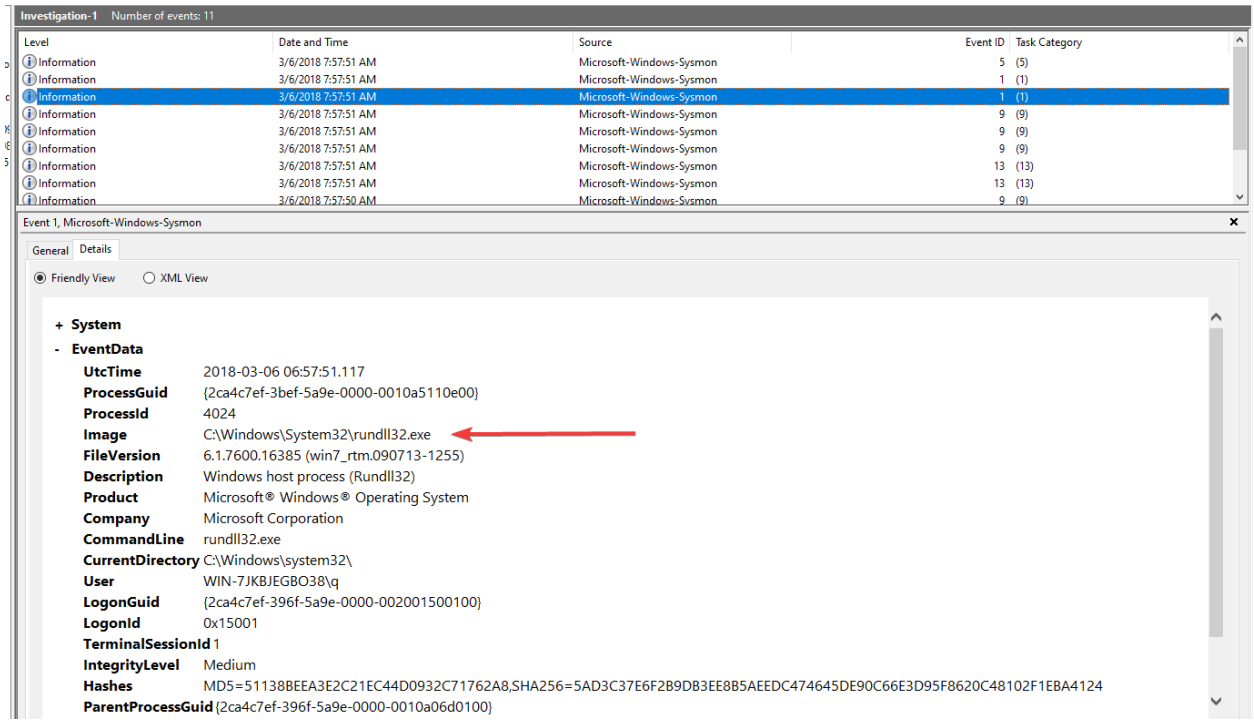
Get-WinEvent -Path ".\Investigation-1.evtx" | Where-Object { $_.Id -eq 9 } | ForEach-Object { $_.ToXml() }

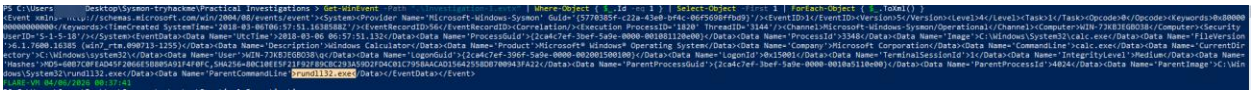




Answer: \Device\HarddiskVolume3

What is the first exe the process executes in Investigation 1?

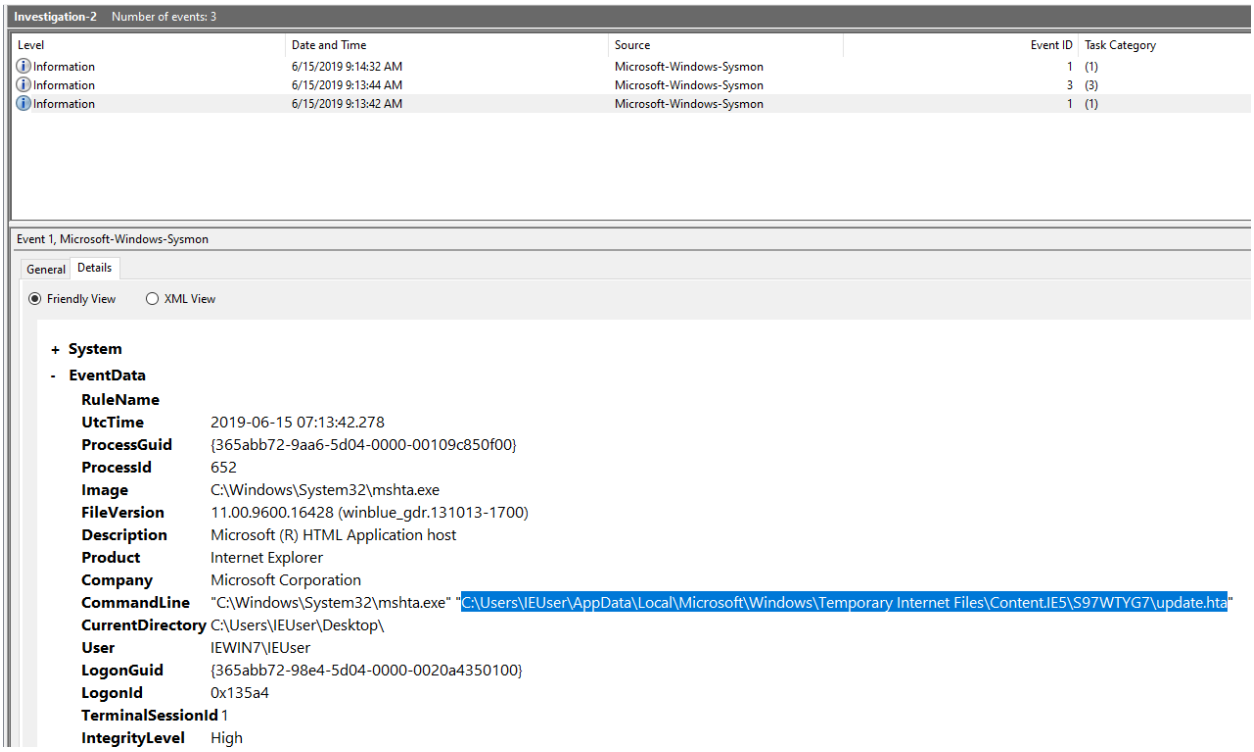


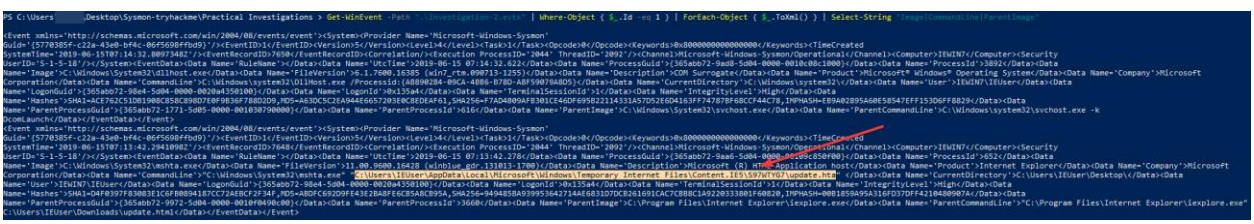


I reviewed the first Sysmon process creation event and found that rundll32.exe launched calc.exe.

Answer: rundll32.exe

What is the full path of the payload in Investigation 2?

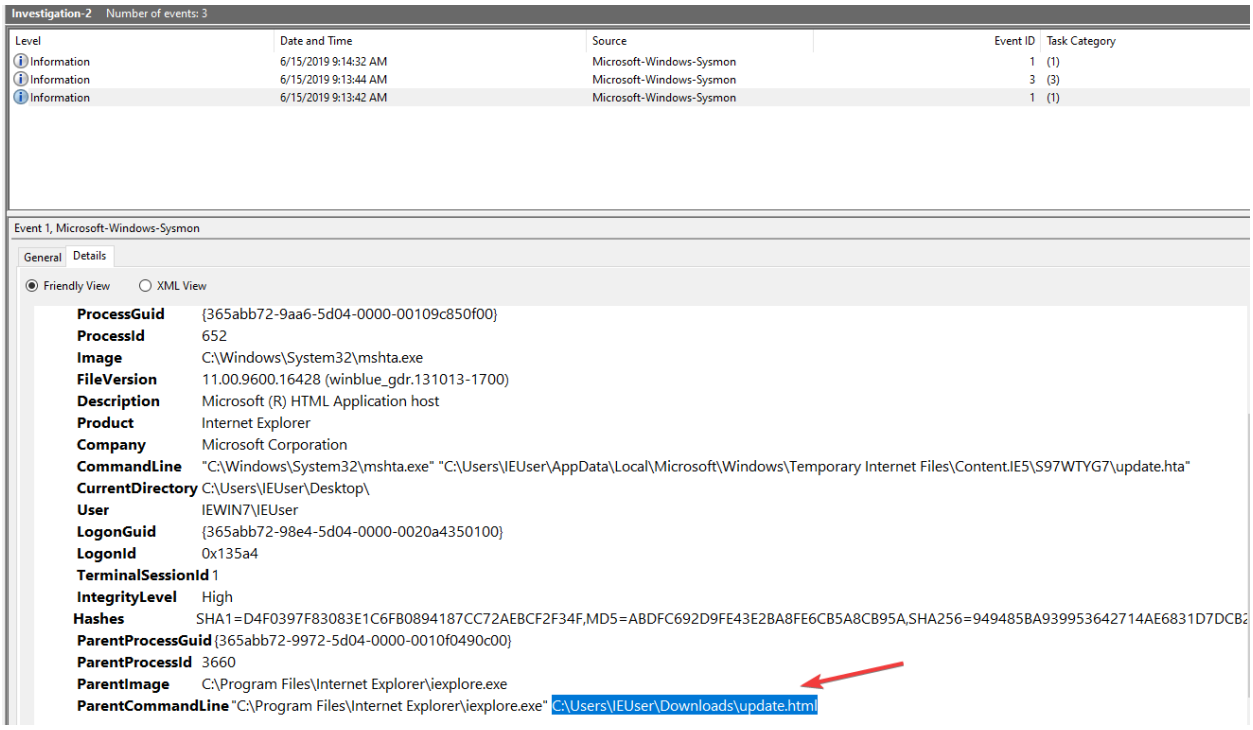




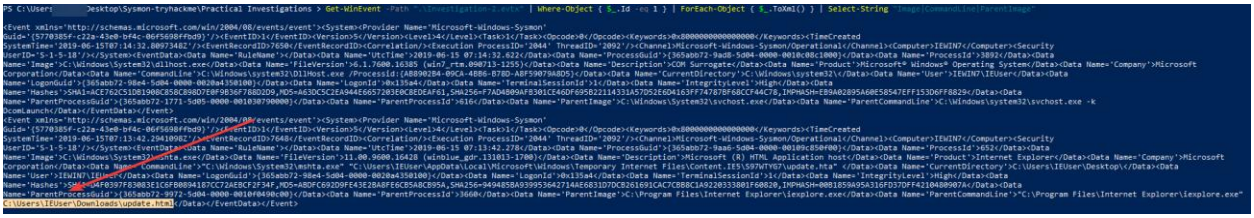
I checked the **Event ID 1** process creation event in Investigation 2 and looked at the **CommandLine** field. That showed mshta.exe launching the payload from *C:\Users\IEUser\AppData\Local\Microsoft\Windows\Temporary Internet Files\Content.IE5\S97WTYG7\update.hta*.

Answer: C:\Users\IEUser\AppData\Local\Microsoft\Windows\Temporary Internet Files\Content.IE5\S97WTYG7\update.hta

What is the full path of the file the payload masked itself as in Investigation 2?



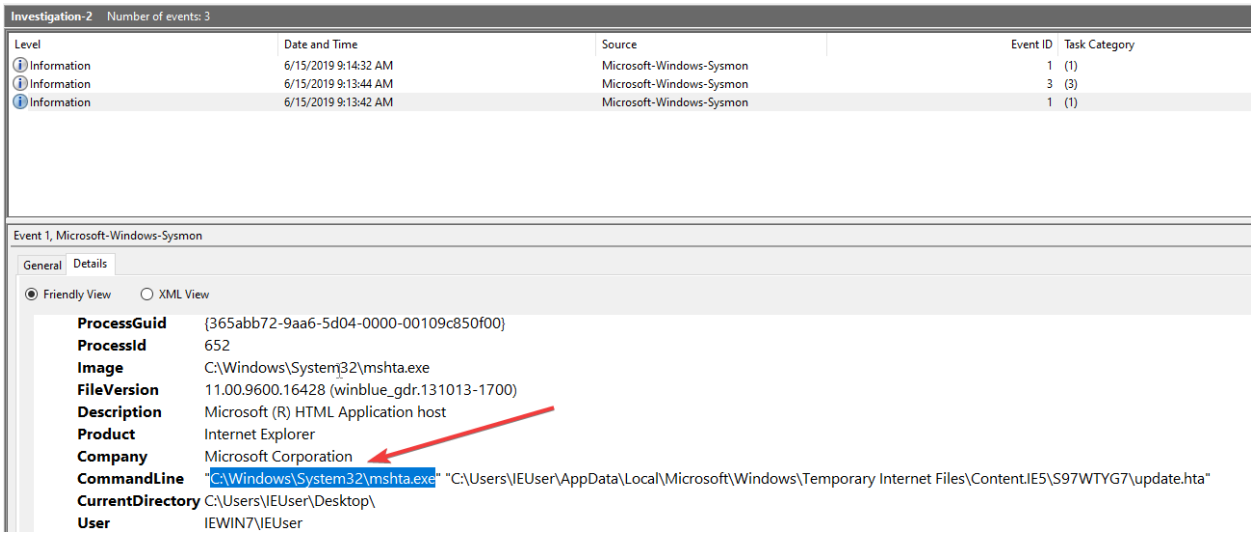
Get-WinEvent -Path ".\Investigation-2.evtx" | Where-Object { $_.Id -eq 1 } | ForEach-Object { $_.ToXml() } | Select-String "Image|CommandLine|ParentImage"

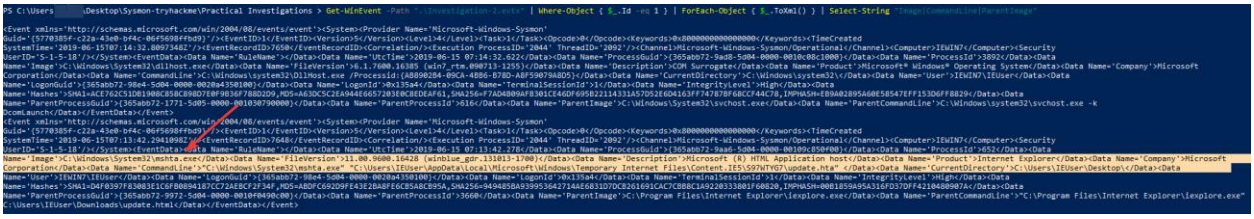


I reviewed the same process creation event and compared the payload path with the original file name. The payload ran as update.hta, but it was disguised as *C:\Users\IEUser\Downloads\update.html*.

Answer: *C:\Users\IEUser\Downloads\update.html*.

What signed binary executed the payload in Investigation 2?



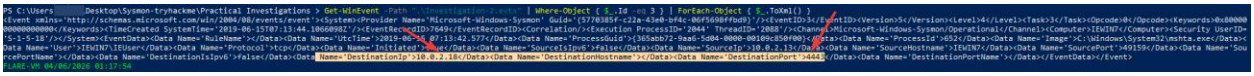


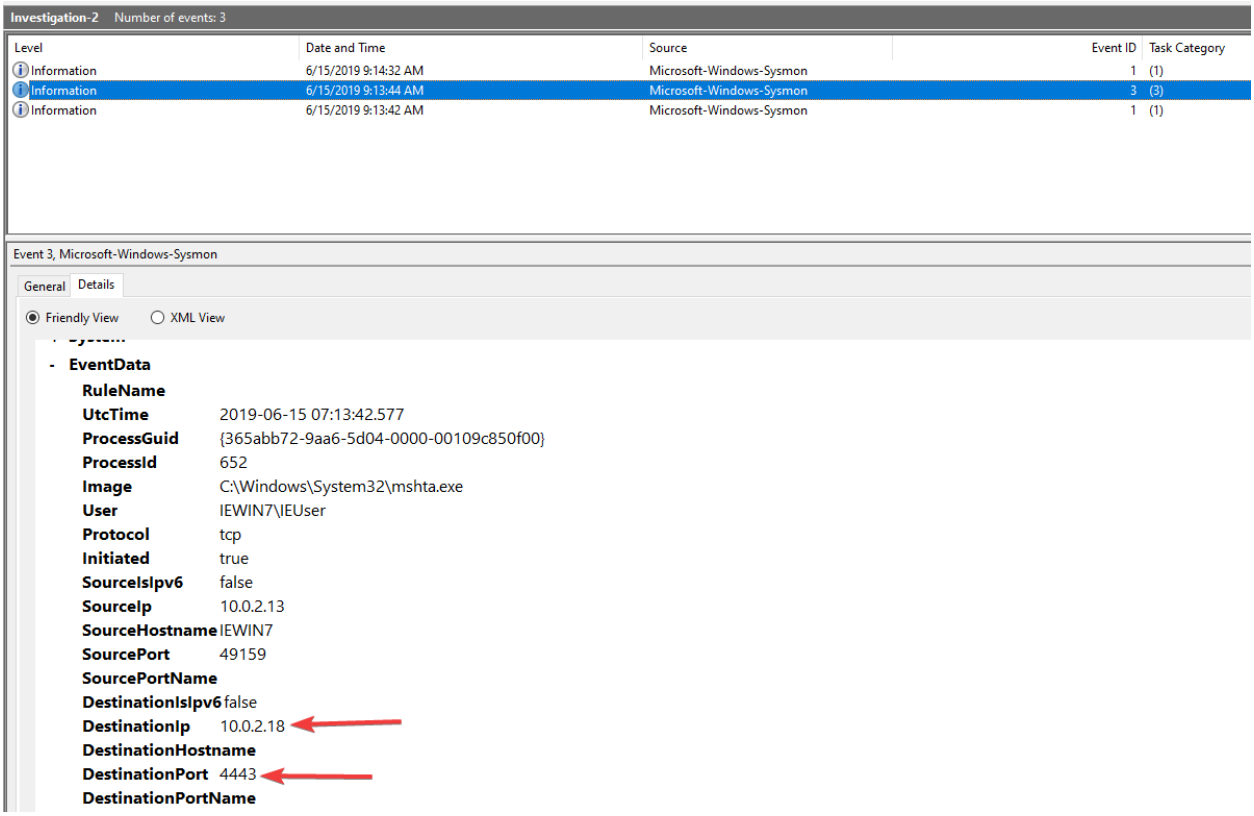
I checked the **Event ID 1** process creation event and looked at the **Image** and **CommandLine** fields. They showed that the payload was executed by the signed Microsoft binary *C:\Windows\System32\mshta.exe*.

Answer: C:\Windows\System32\mshta.exe

What is the IP of the adversary in Investigation 2?

Get-WinEvent -Path ".\Investigation-2.evtx" | Where-Object { $_.Id -eq 3 } | ForEach-Object { $_.ToXml() }

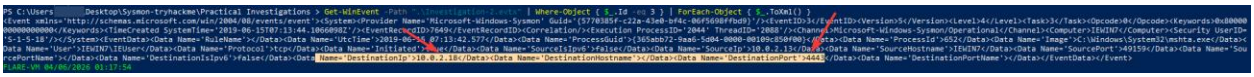




I checked the Event ID 3 network connection event in Investigation 2 and reviewed the IP fields. The suspicious remote address was shown in **SourceIp**, which identified the adversary as 10.0.2.18.

Answer: 10.0.2.18

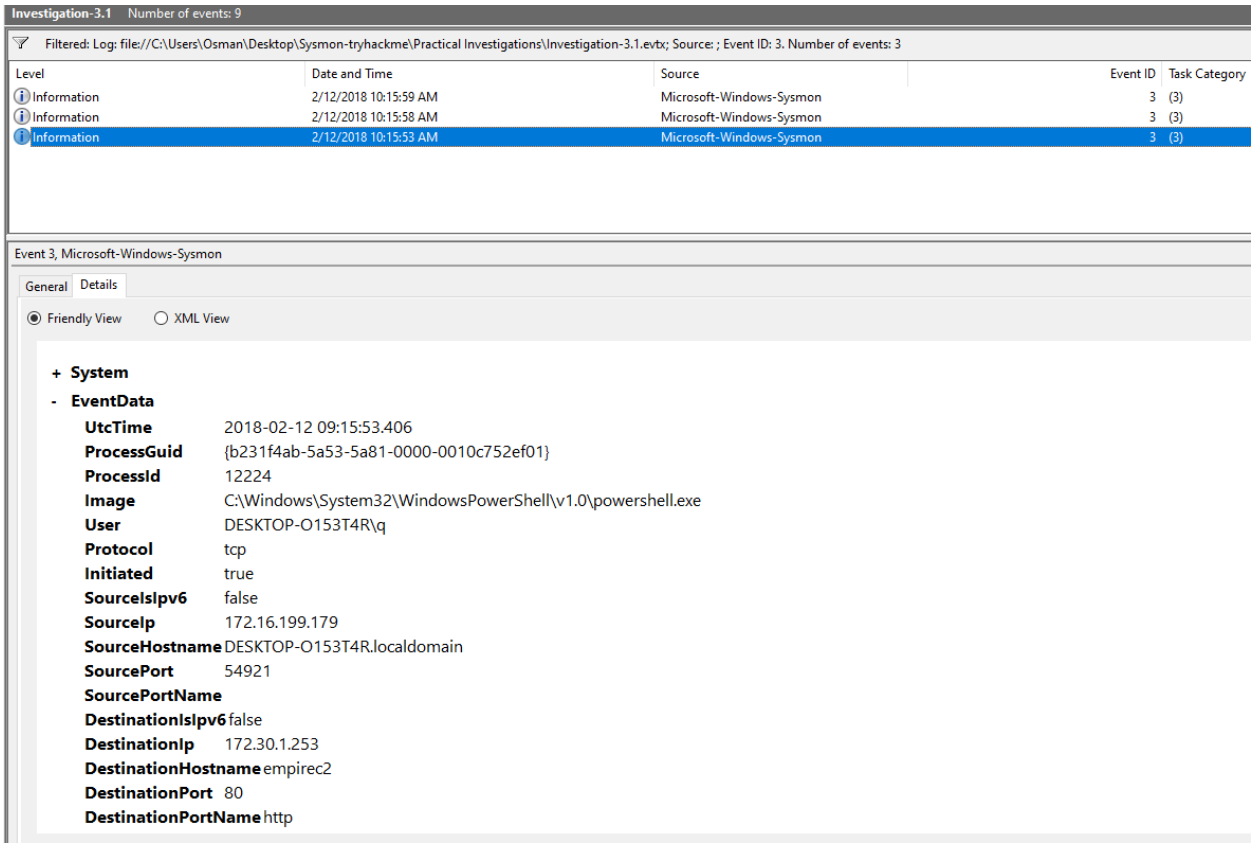
What back connect port is used in Investigation 2?

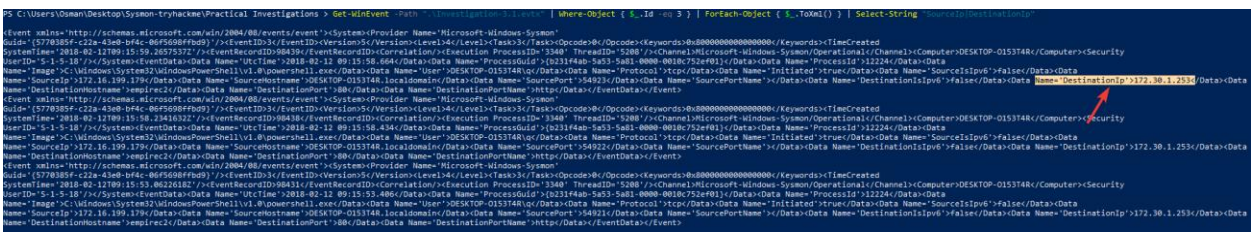


I reviewed the Event ID 3 network connection event and checked the port fields. The suspicious outbound connection was going to destination port 4443, which was the back connect port used by the payload.

Answer: 4443

What is the IP of the suspected adversary in Investigation 3.1?

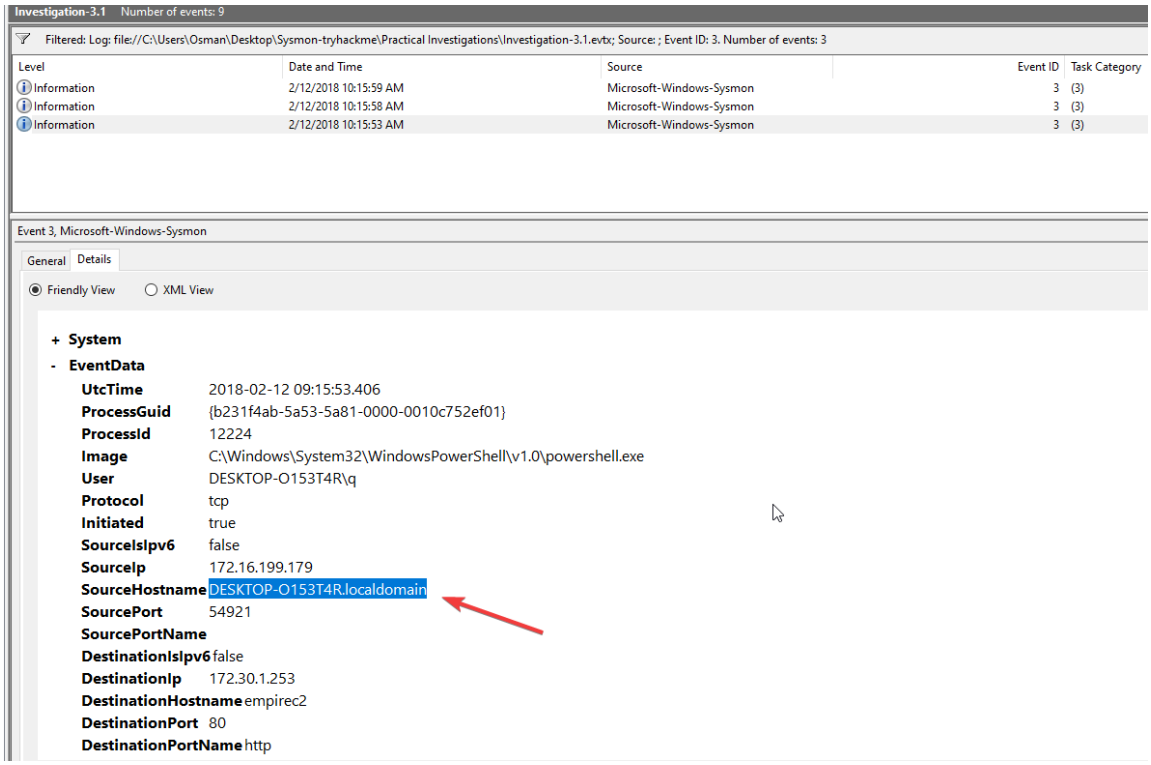




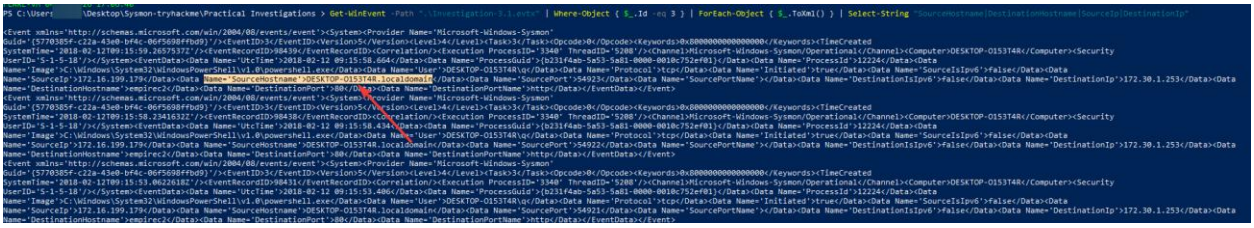
I checked the Event ID 3 network connection event and used the DestinationIp field as the likely adversary address, since that was the remote system the compromised host was connecting to.

Answer: 172.30.1.253

What is the hostname of the affected endpoint in Investigation 3.1?

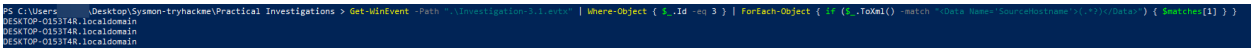


Get-WinEvent -Path ".\Investigation-3.1.evtx" | Where-Object { $_.Id -eq 3 } | ForEach-Object { $_.ToXml() } | Select-String "SourceHostname|DestinationHostname|SourceIp|DestinationIp"



Or

Get-WinEvent -Path ".\Investigation-3.1.evtx" | Where-Object { $_.Id -eq 3 } | ForEach-Object { if ($_.ToXml() -match "<Data Name='SourceHostname'>(.?)</Data>") { $matches[1] } }*

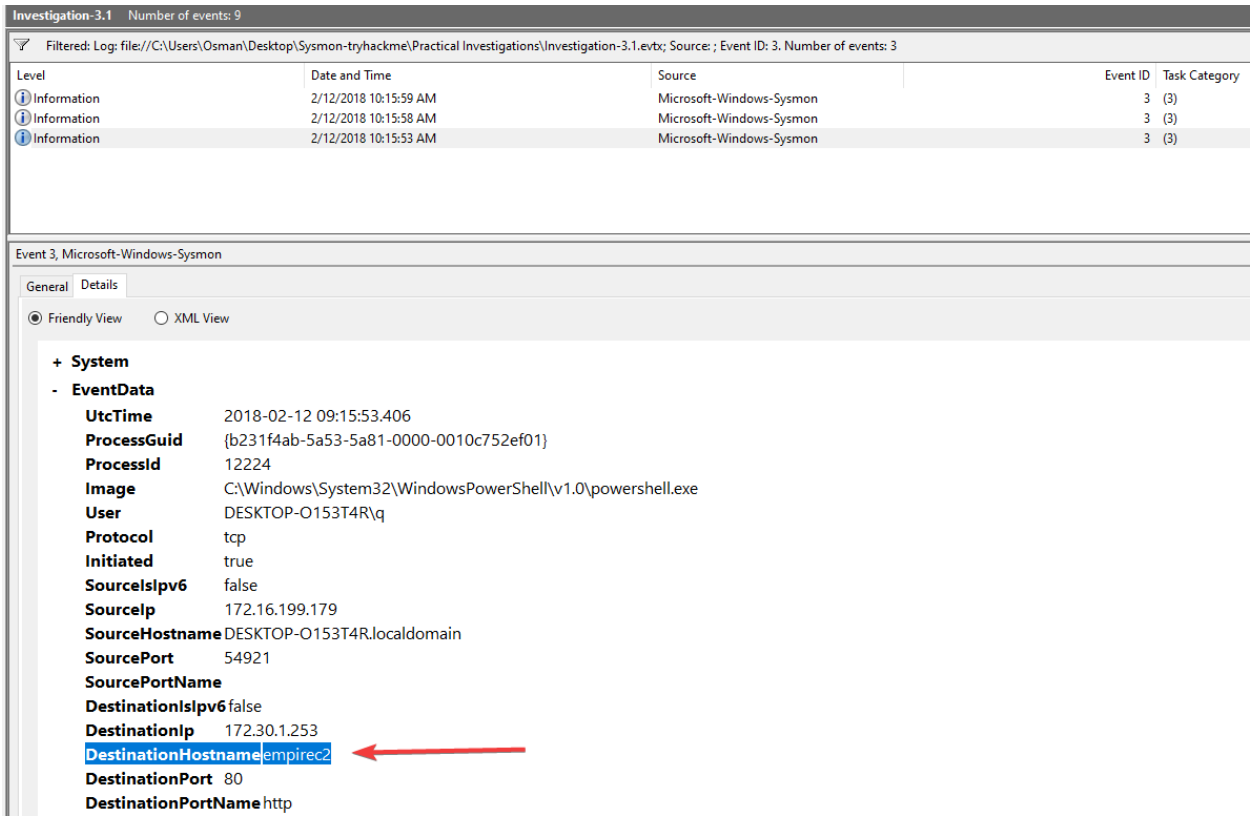


I checked the Event ID 3 network connection logs and used the **SourceHostname** field to identify the affected endpoint as DESKTOP-O153T4R.localdomain.

Answer: DESKTOP-O153T4R

What is the hostname of the C2 server connecting to the endpoint in Investigation 3.1?

```
PS C:\Users\      \Desktop\Sysmon-tryhackme\Practical Investigations > Get-WinEvent -Path ".\Investigation-3.1.evtx" |
>> Where-Object { $_.Id -eq 3 } |
>> ForEach-Object {
>>     $xml = $_.ToXml()
>>     [regex]::Matches($xml, "<Data Name='(SourceHostname|DestinationHostname)'>(.*?)</Data>") |
>>     ForEach-Object { $_.Groups[2].Value }
>> }
DESKTOP-O153T4R.localdomain
empirec2
DESKTOP-O153T4R.localdomain
empirec2
DESKTOP-O153T4R.localdomain
empirec2
```



Get-WinEvent -Path ".\Investigation-3.1.evtx" |

Where-Object { $_.Id -eq 3 } |

ForEach-Object {

$xml = $_.ToXml()

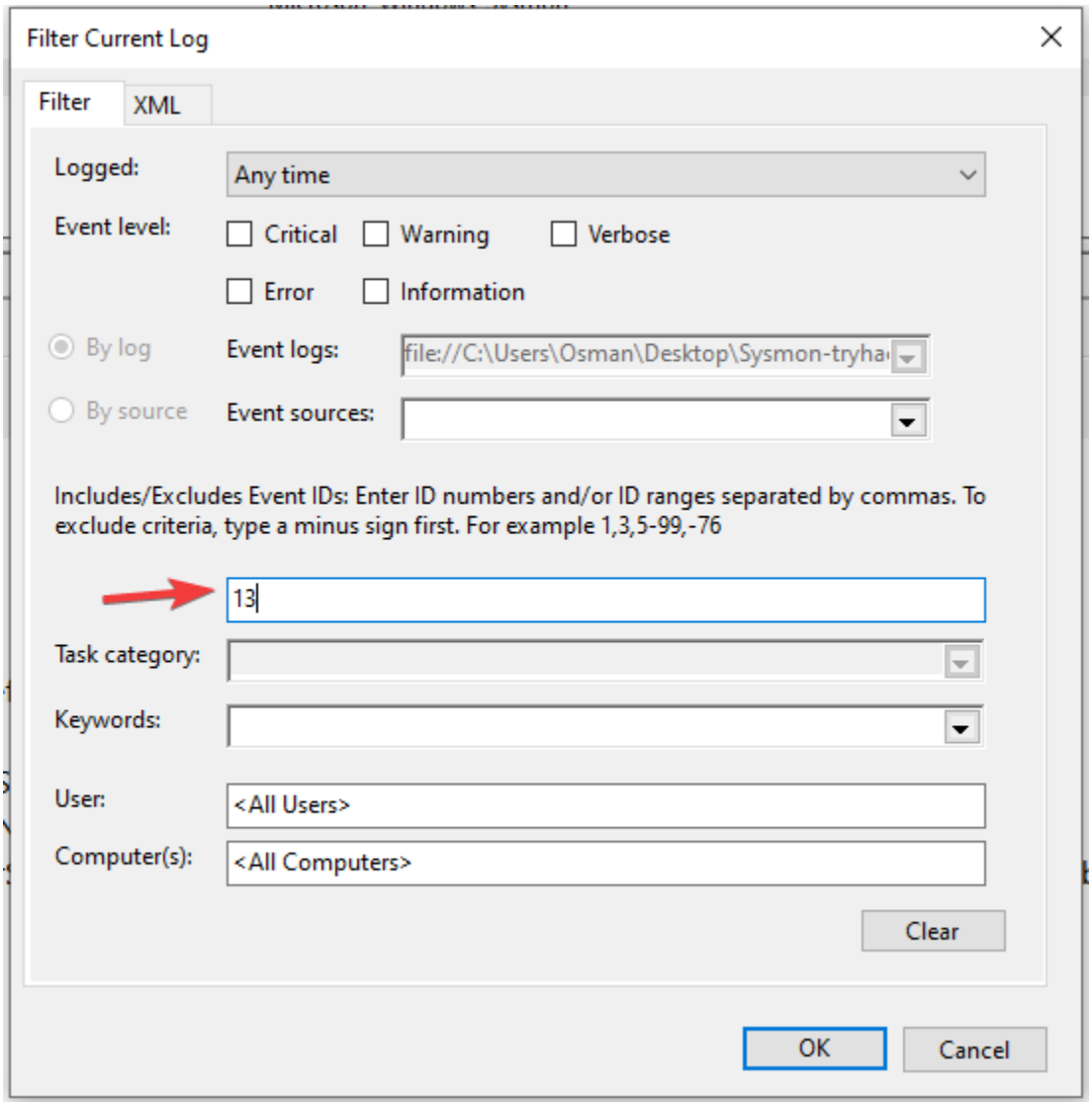
[regex]::Matches($xml, "<Data Name='(SourceHostname|DestinationHostname)'>(.?)</Data>") |*

ForEach-Object { $_.Groups[2].Value }

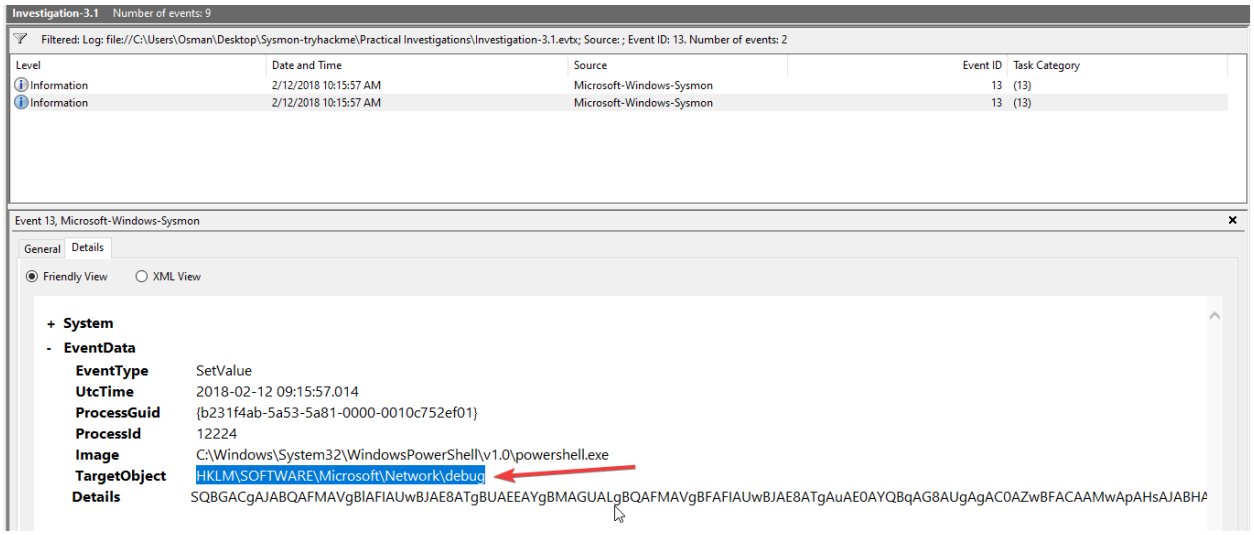
I opened the network connection event and looked at the **DestinationHostname** field. That showed the C2 server hostname as empirec2.

Amswer: empirec2

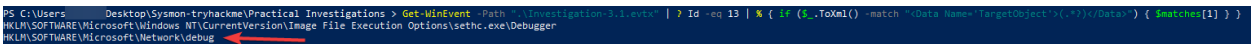
Where in the registry was the payload stored in Investigation 3.1?



In Sysmon, the Event ID 13 is for registry value being set.



Get-WinEvent -Path ".\Investigation-3.1.evtx" | ? Id -eq 13 | % { if ($_.ToXml() -match "<Data Name='TargetObject'>(.?)</Data>") { $matches[1] } }*

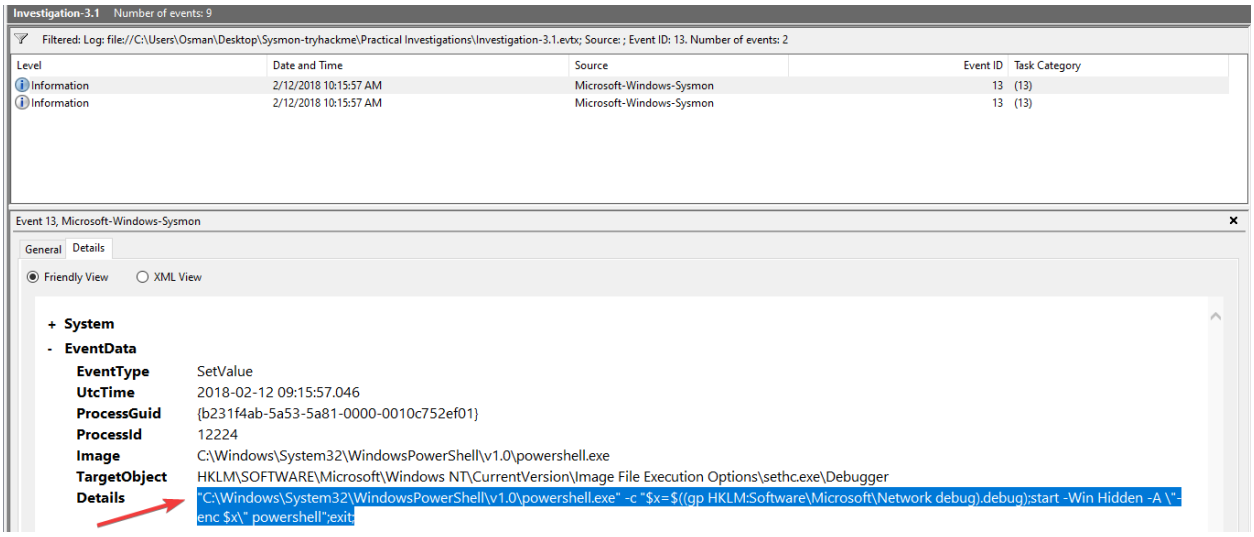


I filtered the log to **Event ID 13** in Event Viewer to focus on registry changes. In the matching event, the **TargetObject** field showed that the payload was stored under HKLM\SOFTWARE\Microsoft\Network\debug.

The payload:

Answer: HKLM\SOFTWARE\Microsoft\Network\debug

What PowerShell launch code was used to launch the payload in Investigation 3.1?

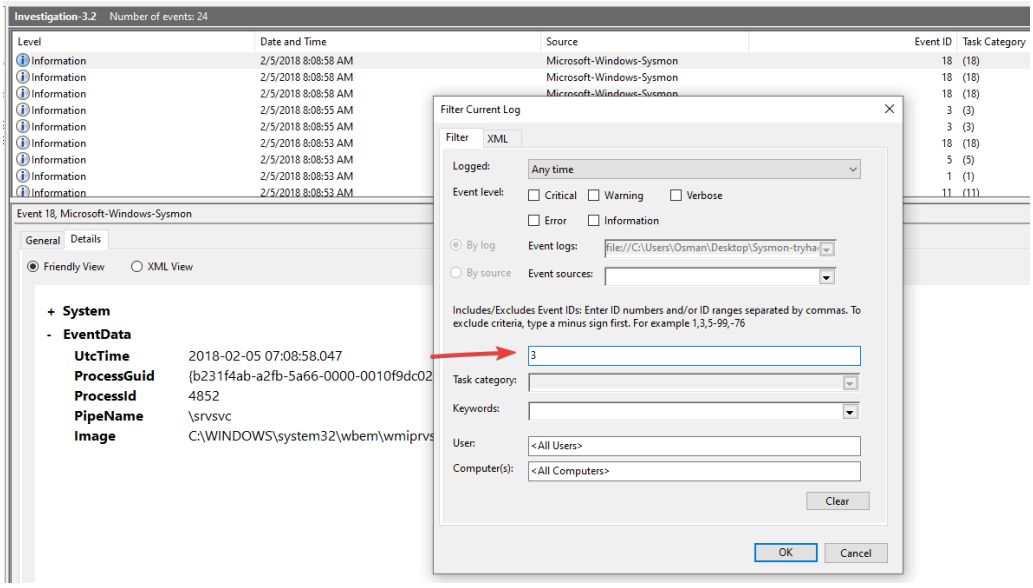


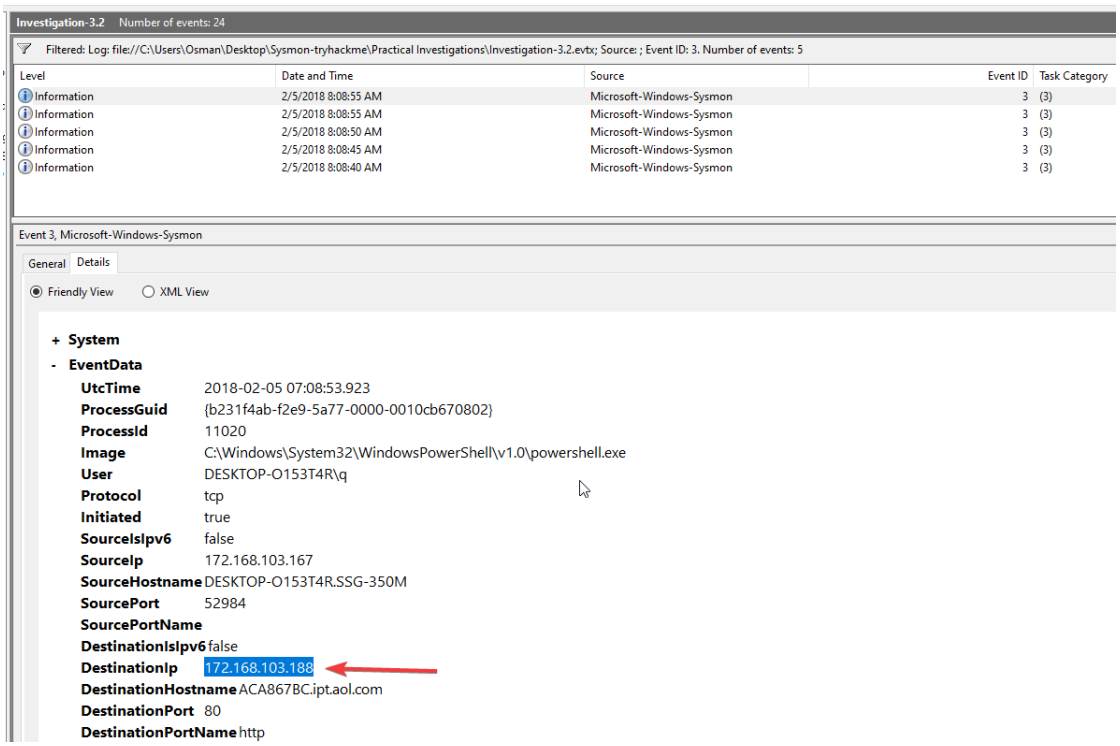
Get-WinEvent -Path ".\Investigation-3.1.evtx" | ? Id -eq 13 | % { if ($_.ToXml() -match "<Data Name='Details'>(.?)</Data>") { $matches[1] } }*

I checked the **Event ID 13** registry modification event in Event Viewer and read the **Details** field. That field showed the PowerShell command used to pull the payload from the registry and launch it in a hidden window.

Answer: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -c "$x=$((gp HKLM:Software\Microsoft\Network debug).debug);start -Win Hidden -A \"-enc $x\" powershell";exit;

What is the IP of the adversary in Investigation 3.2?



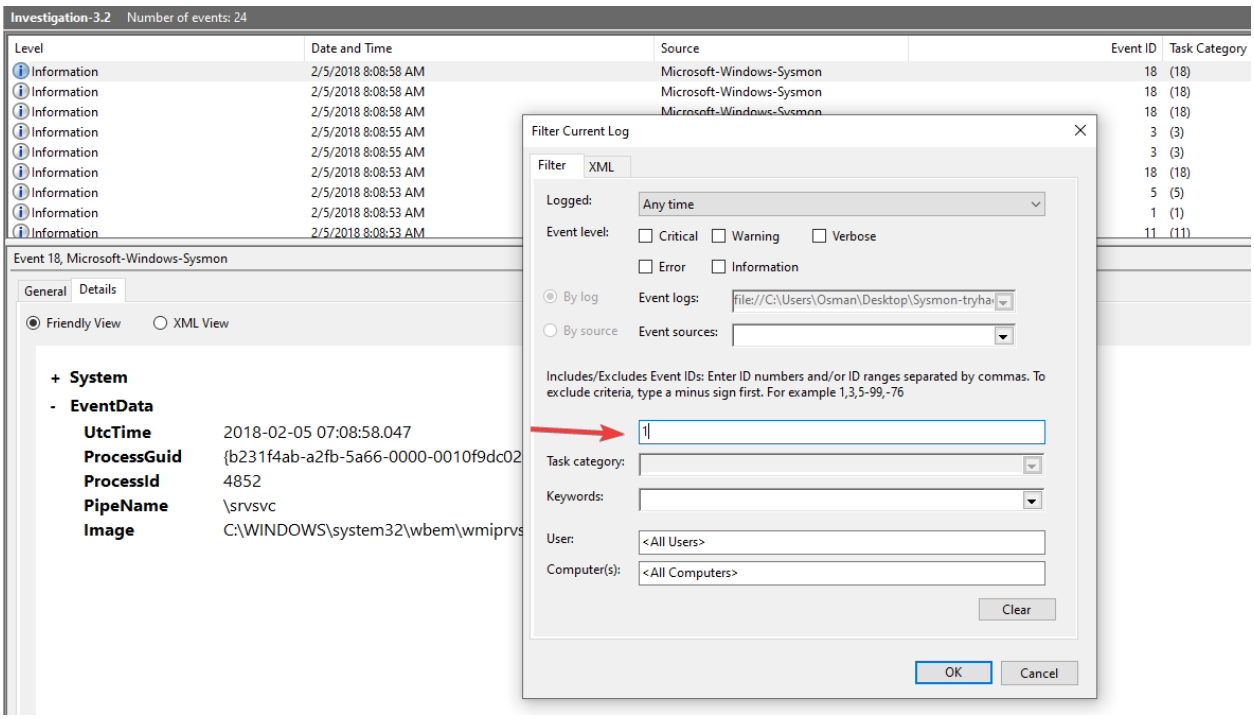


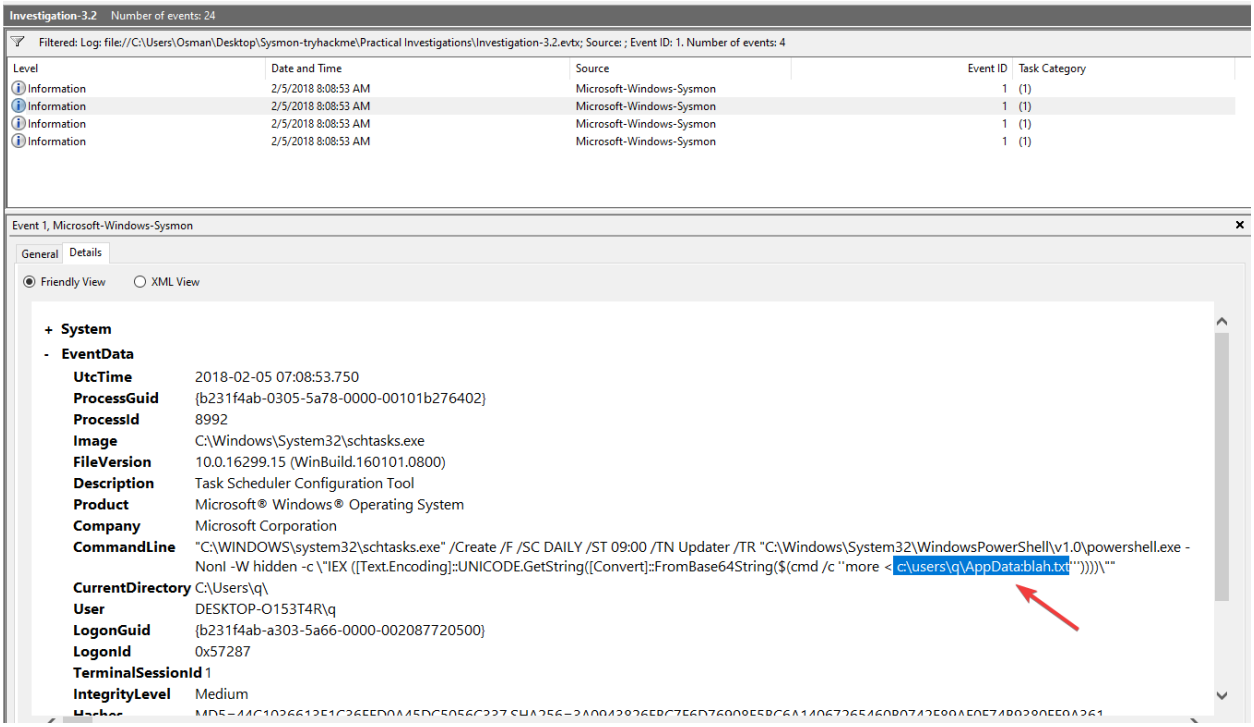

```
Get-WinEvent -Path ".\Investigation-3.2.evtx" | Where-Object { $_.Id -eq 3 } | ForEach-Object { if ($_.ToXml() -match "<Data Name='DestinationHostname'>(.*?)</Data>") { $matches[1] } }
```

I filtered the log for **Sysmon Event ID 3** to review the network connection events. From there, I checked the **DestinationIp** field and identified 172.16.103.188 as the suspected adversary IP in Investigation 3.2.

Answer: 172.168.103.188

What is the full path of the payload location in Investigation 3.2?

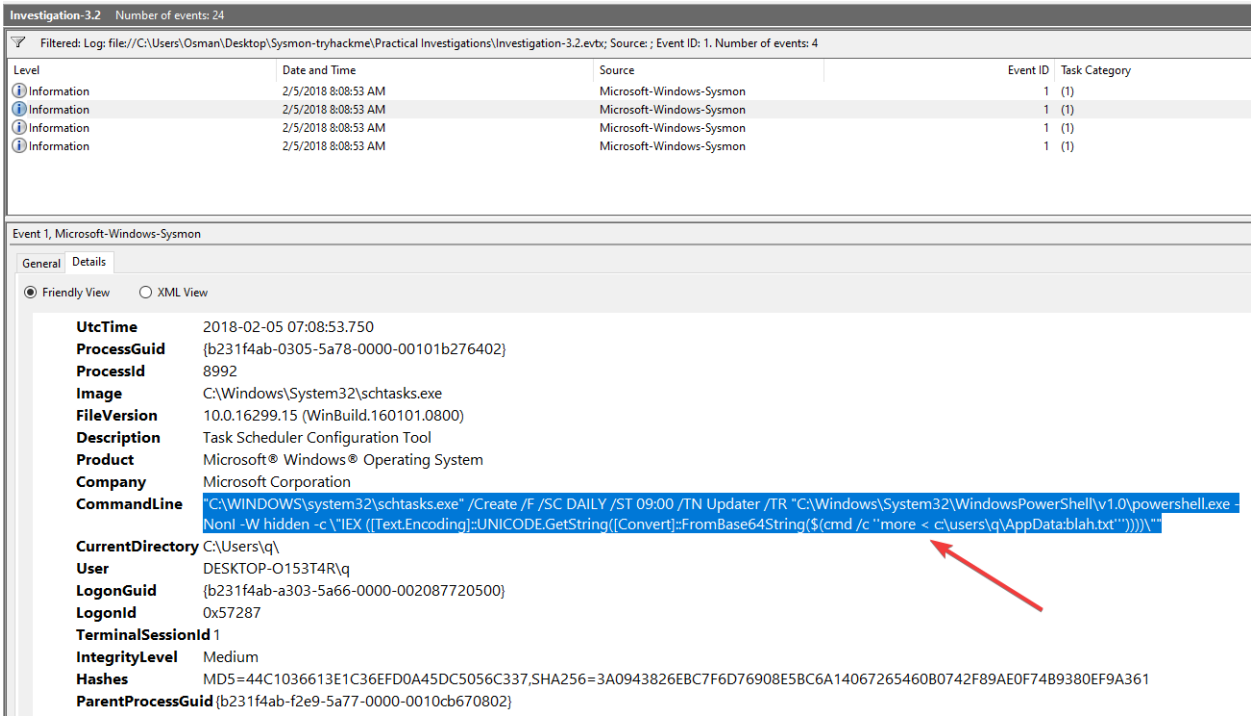




I filtered the log to **Sysmon Event ID 1** to review process creation activity. In the schtasks.exe event, the **CommandLine** field showed the payload being read from C:\Users\q\AppData\blah.txt.

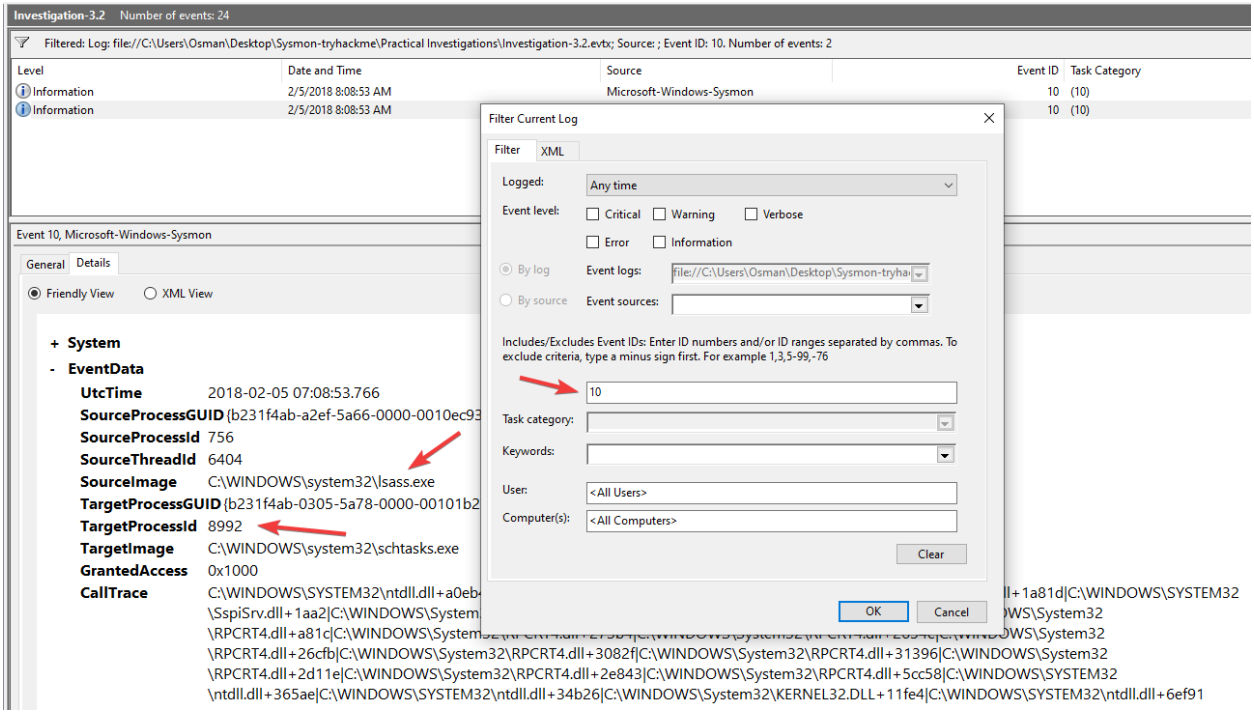
Answer: c:\users\q\AppData:blah.txt

What was the full command used to create the scheduled task in Investigation 3.2?



Answer: "C:\WINDOWS\system32\schtasks.exe" /Create /F /SC DAILY /ST 09:00 /TN Updater /TR "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -NonI -W hidden -c \"IEX ([Text.Encoding]::UNICODE.GetString([Convert]::FromBase64String($(cmd /c ''more < c:\users\q\AppData:blah.txt''))))\""

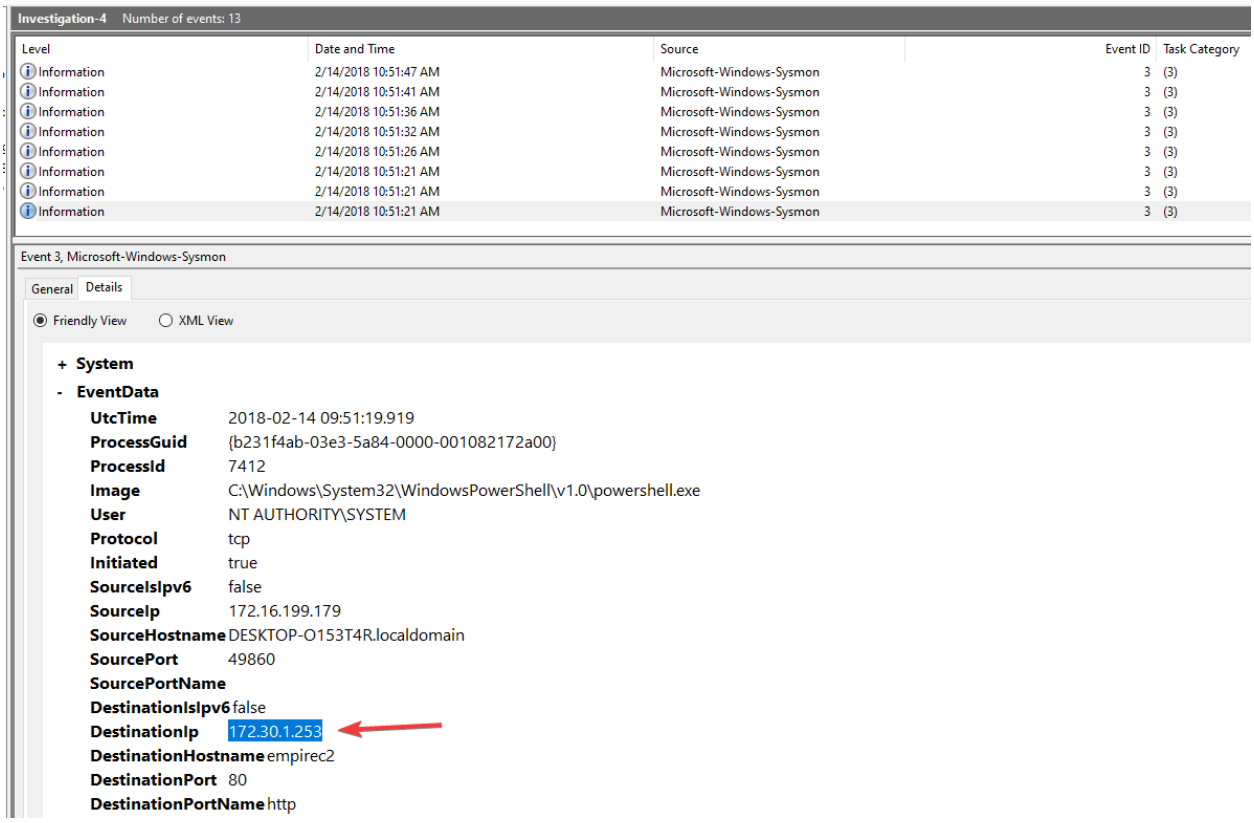
What process was accessed by schtasks.exe that would be considered suspicious behavior in Investigation 3.2?



I filtered the log to **Sysmon Event ID 10** to review process access activity. In the matching event, lsass.exe was shown accessing schtasks.exe, which stood out as suspicious behavior.

Answer: lsass.exe

What is the IP of the adversary in Investigation 4?



Investigation-4 Number of events: 13

Level	Date and Time	Source	Event ID	Task Category
Information	2/14/2018 10:51:47 AM	Microsoft-Windows-Sysmon	3	(3)
Information	2/14/2018 10:51:41 AM	Microsoft-Windows-Sysmon	3	(3)
Information	2/14/2018 10:51:36 AM	Microsoft-Windows-Sysmon	3	(3)
Information	2/14/2018 10:51:32 AM	Microsoft-Windows-Sysmon	3	(3)
Information	2/14/2018 10:51:26 AM	Microsoft-Windows-Sysmon	3	(3)
Information	2/14/2018 10:51:21 AM	Microsoft-Windows-Sysmon	3	(3)
Information	2/14/2018 10:51:21 AM	Microsoft-Windows-Sysmon	3	(3)
Information	2/14/2018 10:51:21 AM	Microsoft-Windows-Sysmon	3	(3)

Event 3, Microsoft-Windows-Sysmon

General Details

Friendly View XML View

+ System

- EventData

UtcTime	2018-02-14 09:51:19.919
ProcessGuid	{b231f4ab-03e3-5a84-0000-001082172a00}
ProcessId	7412
Image	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
User	NT AUTHORITY\SYSTEM
Protocol	tcp
Initiated	true
SourceIsIpv6	false
SourceIp	172.16.199.179
SourceHostname	DESKTOP-O153T4R.localdomain
SourcePort	49860
SourcePortName	
DestinationIsIpv6	false
DestinationIp	172.30.1.253
DestinationHostname	empirec2
DestinationPort	80
DestinationPortName	http

Answer: 172.30.1.253

What port is the adversary operating on in Investigation 4?

DestinationIp	172.30.1.253
DestinationHostname	empirec2
DestinationPort	80

Answer: 80

What C2 is the adversary utilizing in Investigation 4?

Answer: Empire